B3

Báo cáo IPO: Khôi phục quyền truy cập AWS

1. Mô hình IPO

- **Input:** Tài khoản/Mật khẩu AWS + **01 Mã dự phòng (Backup Code)** lưu trữ độc lập.
- **Process:**
  - *Xác thực:* Đăng nhập AWS → Chọn "Troubleshoot MFA" → Nhập mã dự phòng để vào hệ thống.
  - *Hủy mã cũ:* Vào cài đặt IAM → **Xóa (Delete) thiết bị MFA trên điện thoại đã mất** để chặn kẻ nhặt máy.
  - *Cấp mã mới:* Cấu hình MFA lên thiết bị mới + **Sinh bộ Backup Codes mới** (hủy bộ cũ).
- **Output:** Hệ thống an toàn; điện thoại mất bị vô hiệu hóa; quyền truy cập được khôi phục.

2. Tại sao không lưu Backup Codes dạng ảnh trong điện thoại?

- **Lộ diện khi mất máy:** Kẻ nhặt được điện thoại có thể vào thư viện ảnh, dùng tính năng tìm kiếm chữ (OCR) với từ khóa "AWS", "Backup" để lấy mã.
- **Rò rỉ qua ứng dụng:** Các app bên thứ ba (chỉnh ảnh, game) có quyền xem bộ sưu tập ảnh dễ dàng thu thập và gửi mã về máy chủ của chúng.
- **Nguy cơ từ đám mây:** Ảnh tự động đồng bộ lên iCloud/Google Photos; nếu tài khoản cloud này bị hack, hệ thống AWS sẽ sụp đổ theo.